

BLUE TEAM / NETWORK SECURITY LAB REPORT

CySA2_Lab — Reconnaissance, Traffic Analysis, Vulnerability Assessment & IDS Detection

Thamsanqa Kurtis Tshili | Cybersecurity / SOC Portfolio Project | 2026

1. Executive Summary

This project demonstrates a practical defensive-security workflow in an isolated virtual enterprise network. The lab used Windows Server 2016, Windows 10, Kali Linux and Cisco routing infrastructure. Activities included network reconnaissance, packet capture and analysis with Wireshark, an authorised FTP brute-force simulation, vulnerability scanning with Nessus, and intrusion detection with Snort.

The project is relevant to SOC work because it connects attacker activity to observable network telemetry, vulnerability findings, detection rules and remediation. It also demonstrates an attacker-informed defensive mindset: understanding how reconnaissance and authentication attacks appear on the network and how an IDS can detect them.

2. Objectives

- Build an isolated Windows/Linux security-testing environment using VMware and GNS3.
- Perform reconnaissance against lab systems and observe resulting traffic.
- Analyse network packets and TCP flags using Wireshark.
- Simulate an FTP brute-force attack against the lab FTP service and analyse the outcome.
- Perform vulnerability assessment of Windows Server using Nessus.
- Configure Snort rules to detect FTP connectivity and FIN-based scanning activity.
- Develop defensive recommendations based on observed attack paths and findings.

3. Lab Architecture

The lab connected Windows Server 2016, Windows 10, Kali Linux, a Cisco 3745 router and an Ethernet switch through GNS3/VMware. Windows Server was configured as the ignite.net domain controller and Windows 10 joined the domain. The router provided routing and DHCP services for the Kali segment.

- Windows Server / DC: 192.168.2.1/24
- Windows 10 / Client-PC: 192.168.2.10/24
- Cisco interface facing Windows systems: 192.168.2.200/24
- Cisco interface facing Kali: 172.31.5.10/24
- Kali network: 172.31.5.0/24

4. Security Testing Methodology

- Establish the isolated lab and verify connectivity.
- Perform reconnaissance from Kali against the Windows network.
- Capture traffic on Windows Server with Wireshark.
- Correlate scan activity with packet-level evidence.
- Expose FTP and conduct a controlled brute-force simulation.
- Assess the server for vulnerabilities using Nessus.
- Configure Snort detection rules for suspicious FTP and scanning activity.
- Document findings, defensive controls and monitoring improvements.

5. Reconnaissance & Network Visibility

Nmap was used from Kali to perform a ping scan of 192.168.2.0/24 and full scans against the Windows Server and Windows 10 systems. Wireshark was running on Windows Server to provide packet-level visibility during reconnaissance.

The completed project recorded TCP SYN traffic, TCP ACK traffic and ICMP timestamp traffic originating from Kali. Example traffic included connections involving ports 80, 1025 and 1720. This demonstrates how active reconnaissance produces telemetry useful for detection.

- Repeated connection attempts to many ports can indicate service discovery or reconnaissance.
- ICMP and TCP scanning behaviour can provide early indicators of host discovery and enumeration.
- Source IP, destination IP, destination port, TCP flags and timing are useful investigation fields.
- Network monitoring can correlate repeated connection attempts from one source into a reconnaissance incident.

6. Wireshark Traffic Analysis

The project filtered packets containing the TCP FIN flag. FIN indicates that a TCP endpoint has finished sending data and is beginning orderly TCP connection termination. A normal TCP close involves FIN, ACK, peer FIN and final ACK.

For SOC investigations, a FIN packet is not inherently malicious. Analysts should correlate TCP flags with source, destination, ports, frequency, timing and surrounding traffic. In this project, FIN-only traffic was also used as part of the Snort scan-detection logic.

7. FTP Brute-Force Simulation

The Windows Server was configured as an FTP server on TCP/21. Kali was used to identify the FTP service and perform an authorised credential-testing simulation using Metasploit and supplied wordlists. The project documented a successful credential combination in the controlled lab.

- Prefer SFTP or FTPS over unencrypted FTP where file transfer is required.
- Use strong, unique passwords and remove weak/default credentials.
- Restrict FTP access to trusted networks or approved source IP ranges.
- Implement account lockout or rate limiting where supported.
- Monitor repeated authentication failures and successful logins following multiple failures.
- Alert on unusual authentication volume and repeated username targeting.
- Use MFA where supported.

8. Vulnerability Assessment

A basic Nessus scan was performed against Windows Server using a policy named 'Server Scan'. The documented findings included a physical-path disclosure issue associated with a nonexistent-page response and an SSL certificate trust issue.

Physical Path Disclosure: error responses can expose server filesystem information, assisting reconnaissance and potentially guiding further attacks. Remediation includes generic/custom error handling that does not reveal physical paths.

SSL Certificate Cannot Be Trusted: an improperly trusted certificate can create trust, impersonation and man-in-the-middle risks. Remediation includes trusted certificates where appropriate, correct certificate chains/hostnames, current TLS configuration and certificate monitoring.

The project also correctly identified the role of vulnerability scanning in penetration testing: scanners rapidly identify candidate weaknesses and help prioritise deeper manual validation. Scanner findings should be validated before being treated as confirmed exploitable vulnerabilities.

9. Snort IDS Detection

Snort was configured with local rules to detect inbound TCP connections to the FTP service and scan activity characterised by FIN-only TCP flags. The FTP rule used the alert message 'FTP Connectivity Detected', while the scan rule used 'Server Services Scanned!!'. Both rules were rate-limited to the first five alerts within five seconds.

- The FTP rule provides visibility into connections to a sensitive service.
- The scan rule demonstrates signature-based detection of reconnaissance.
- Rate limiting helps reduce duplicate alerts during bursts.
- Detection rules should be tuned against normal traffic to reduce false positives.
- A production SOC would enrich alerts with asset, user, threat-intelligence and historical context.

10. Incident-Response Interpretation

If similar activity occurred in production, an analyst could investigate it as a potential reconnaissance-to-authentication attack chain. Initial triage would establish the source, targeted asset, targeted services, authentication outcomes and timestamps. The analyst would determine whether activity was authorised, assess potential credential compromise, review authentication and endpoint logs, and escalate or contain as appropriate.

- Reconnaissance observed: repeated scan/connection activity from a source host.
- Service identified: FTP available on TCP/21.
- Authentication activity observed: repeated login attempts.
- Potential compromise: successful authentication following failures.
- Validation: correlate source IP, account, endpoint activity and FTP logs.
- Containment: restrict the source and reset/disable compromised credentials if justified.
- Remediation: remove unnecessary FTP exposure, strengthen authentication and improve monitoring.

11. MITRE ATT&CK Mapping

- T1046 — Network Service Scanning: reconnaissance of hosts/services through network scanning.
- T1110 — Brute Force: repeated authentication attempts against FTP.
- T1078 — Valid Accounts: successful use of valid credentials in the controlled lab.
- Defensive network-traffic analysis: packet capture was used to understand attacker behaviour; the project did not demonstrate credential sniffing.

12. Skills Demonstrated

- Security monitoring and packet analysis
- Wireshark filtering and TCP/IP analysis
- Nmap reconnaissance analysis
- FTP attack-path analysis
- Nessus vulnerability assessment
- Windows Server and Active Directory administration
- GNS3/VMware virtual lab construction
- Risk-based remediation and security reporting
- Attacker-to-defender correlation

13. Portfolio Improvements

- Add Windows Event Logs and Sysmon to the lab.
- Ingest Snort and Windows telemetry into a SIEM such as Microsoft Sentinel, Wazuh or Splunk.
- Create correlation rules for reconnaissance followed by brute-force activity.
- Add detections for PowerShell abuse, suspicious process creation and persistence.
- Create a formal SOC incident ticket for each scenario containing severity, evidence, timeline, IOCs, containment and remediation.

14. Evidence / Screenshots

The original academic specification requires screenshots. For GitHub, use only screenshots you personally captured from your lab and redact passwords, licence keys, email addresses and other sensitive information.

- GNS3 topology
- Windows Server / Active Directory configuration
- Nmap reconnaissance output
- Wireshark scan traffic
- Wireshark FIN filter
- FTP service configuration
- Metasploit FTP test result
- Nessus vulnerability results
- Snort local.rules configuration
- Snort alerts triggered by test traffic

15. Conclusion

This project demonstrates an attacker-informed defensive workflow: build an enterprise-style lab, generate controlled attack activity, capture and analyse telemetry, identify vulnerabilities, create IDS detections and recommend mitigations. Its strongest portfolio value is the connection between offensive techniques and defensive visibility, demonstrating foundations for SOC analysis, incident response, vulnerability management and detection engineering.

document. The report preserves the documented project results and clearly labels future improvements as recommendations.